Ecole Supérieure d'Informatique et du Numérique
COLLEGE OF ENGINEERING & ARCHITECTURE

- TP 08: Handling TLS/SSL
- Nom de l'enseignant : Pr Anass Sebbar
- Niveau : 4ème année Ing

TP n° 05

Transport Layer Security / Secure Socket Layer

1- Objectifs :

Wireshark is a very popular software to capture and analyze network traffic. Wireshark can capture both wired and wireless network traffic. Sur l'Internet moderne, la confidentialité et la sécurité sont des priorités majeures. C'est pourquoi le protocole TLS (Transport Level Security) (et son prédécesseur SSL) est conçu pour crypter le trafic lorsqu'il circule sur le réseau. Cela permet aux ordinateurs d'utiliser les mêmes protocoles sous-jacents pour formater les données (comme HTTP) mais d'ajouter un niveau de sécurité (en le transformant en HTTPS). Le problème de SSL/TLS pour les professionnels de la cybersécurité est qu'il fonctionne. Bien que les normes de cryptage aient été développées à des fins positives, les méchants les utilisent également. Dans cet article, nous allons décrire comment effectuer un décryptage SSL/TLS dans Wireshark.

Nous allons nous intéresser à ce qui suit :

- Introduction Wireshark.
- Analywe traffic TCP
- Phishing attack
- Analyze TLS Handshake with Wireshark

2- Consignes :

The report of the practical work must be submitted one week after the practical session and submitted in the connect platform. The practical work must be worked on in class in groups of 2 students maximum. The groups in the practical work must remain the same for the reports and for the next practical sessions.

Wireshark Installation

Install Wireshark on your machine

$ sudo apt-get install wireshark

Launch Wireshark

$ sudo wireshark &

When Wireshark is first run, a default, or blank window is shown. To list the available network interfaces, select the **Capture- >Interfaces** menu option as shown in Figure 1.

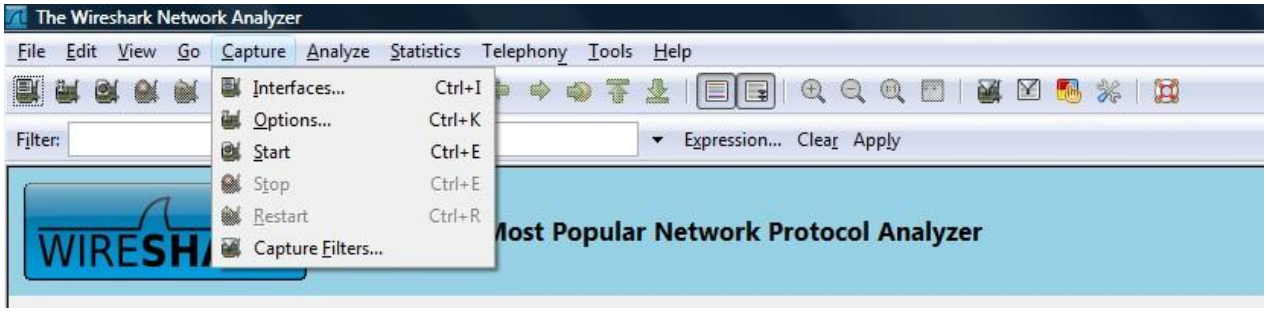


Figure 1. Wireshark interfaces.

Wireshark should display a popup window. To capture network traffic click the **Start** button for the network interface you want to capture traffic on.
Note: The Packets column, to the left of the start button shows the total number of incoming packets for each interface.

Generate some network traffic with a Web Browser. Your Wireshark window should show the traffic, and now look something like Figure 2.
Note: The web browser produced traffic to and fromport 80, which Wireshark interprets as **HTTP** in the **Protocol** column.

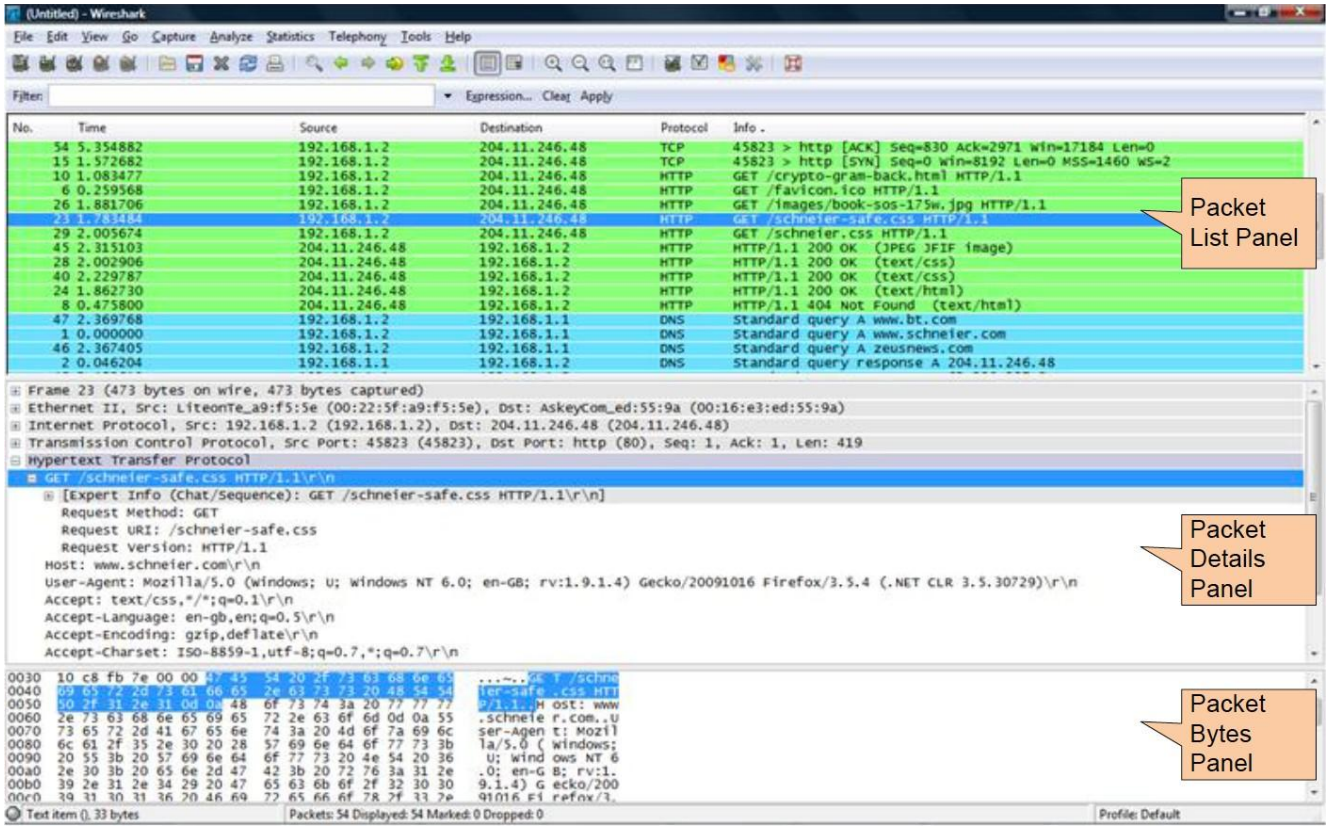


Figure 2. Wireshark capturing traffic

You will also see traffic from other machines in the computer lab given that Wireshark captures traffic in promiscuous mode by default. You can check that the promiscuous modeis checked by opening **Capture -> Options.**

The capture is split into 3 parts:

1. **Packet List Panel**– _this is a list of packets in the current capture. It colors the packets based on theprotocol type. When a packet is selected, the details are shown in the two panels below.
2. **Packet Details Panel**– _this shows the details of the selected packet. It shows the different protocolsmaking up the layers of data for this packet. Layers include Frame, Ethernet, IP, TCP/UDP/ICMP, and application protocols such as HTTP.
3. **Packet Bytes Panel** – _shows the packet bytes in Hex and ASCII encodings.

Search through your capture, and find an **HTTP** packet containing a **GET** command. Click on the packet inthe **Packet List Panel**. Then expand the HTTP layer in the **Packet Details Panel**, from the packet**.**

A Packet Capture or ***'pcap'*** can be saved to disc, for later analysis. To save a capture, select **File->Save As**, and use the dialog box. This creates a '**.pcap' file**. This basic 'Save As' saves all the captured packets to the file.

Note: A **.pcap** file is a common format which many tools can read and write. For example a **tcpdump** or **windump** output file is in this format, and can be read into **Wireshark** for analysis.

Other useful network forensic tools, which can operate on .pcap files, include **NetworkMiner** – another capture and analysis tool, **tcpstat** --- for generating capture statistics, and **Snort** – for generating intrusion alerts from capture files.

Wireshark Analysis --- Display Filters

Right click on the **Source Port** field in the **Packet Details Panel**. Select **Apply as Filter-- >Selected**

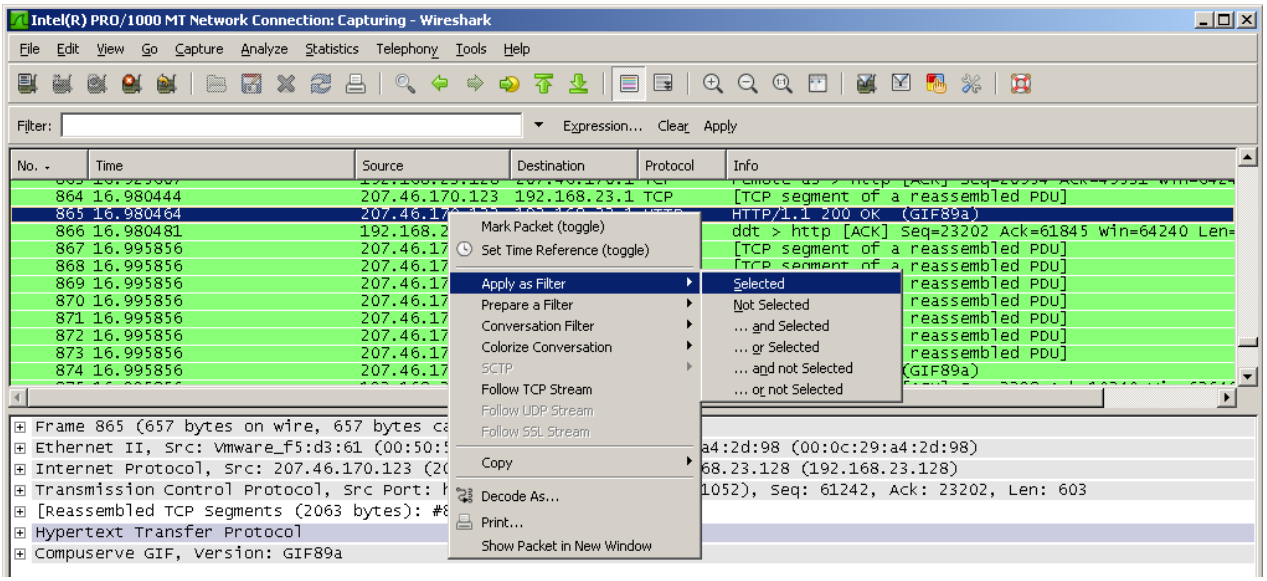


Figure 3. Display filters

Wireshark automatically generates a **Display Filter**, and applies it to the capture. The filter is shown in the **Filter Bar**, below the button toolbar. Only packets captured with a Source Port of thevalue selected should be displayed. The window should be similar to that shown in Figure 3. This same process can be performed on most fields within Wireshark, and can be used to include or exclude traffic.

Wireshark Analysis --- TCP Conversations

Start a capture, and generate some Web traffic by going to www.schneier.com, and then stop the capture. Scroll back to the top of the capture trace. Find the first SYN packet, sent to the Web Server. This signifies the start of a TCP 3-way handshake.

If your having trouble finding the first SYN packet, select the **Edit->Find Packet** menu option. Select the **Display Filter** radio button and enter a filter of **tcp.flags.** (at this point you should get a list of the flags tochoose from). Choose the correct flag, **tcp.flags.syn** and add **== 1**. Hit the **Find** button, and the first SYN packet in the trace should be highlighted.

Note: The **Find Packet** function can also be used to search for a Hex signature – such as an attack signature, or to search for a string – such as a protocol command --- in a Packet Capture (**pcap**).

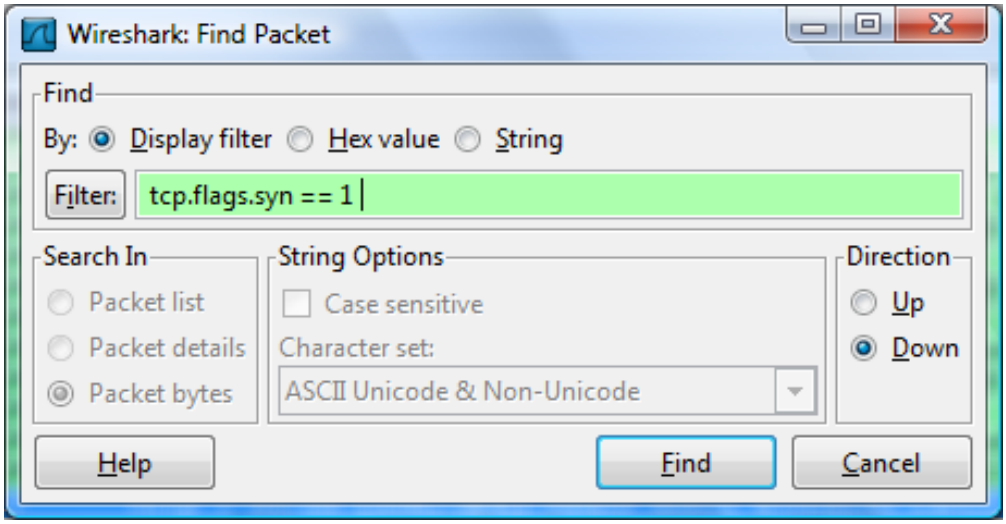


Figure 4. Find packet

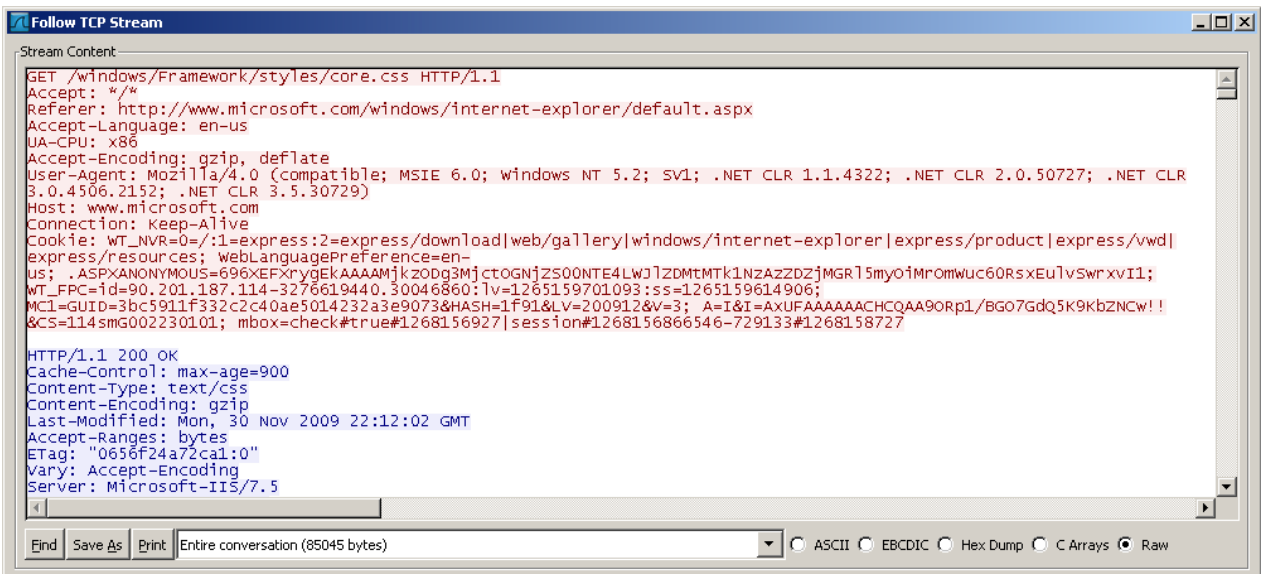


Figure 5. Follow TCP stream

A quick way to create a **Wireshark Display Filter** to isolate a TCP stream is to right click on a packet in the **Packet List Panel** and select **Follow TCP Stream.** This creates an automatic Display Filter which displays packets from that TCP session only. It also pops up a session display window, containing an ASCII representation of the reassembled TCP session (client packets in red, server packets in blue). The window should look something like Figure 5**.**

- TP 05: network security
- Nom de l'enseignant : Pr Anass Sebbar
- Niveau : 4ème année Ing

This is very useful for viewing human readable protocol payloads of conversations, such as with the **HTTP, SMTP, and FTP** protocols.
If you close the popup window, Wireshark now only shows the packets from the selected TCPStream. You should be able to identify the 3-way handshake as the first three packets.

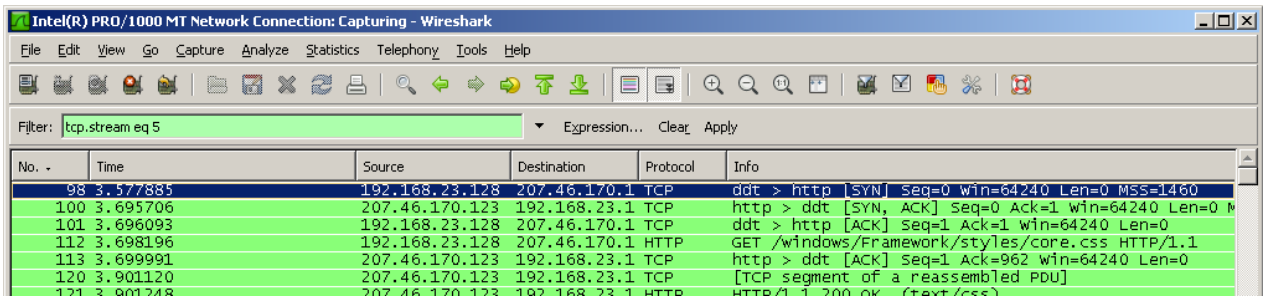


Figure 6. TCP stream

Often captures should be saved to disc, for later analysis. To save a capture, select **File->Save As**, and use the dialog box as normal. This creates a **pcap** file, which many tools read and write. For example a tcpdump output file is in this format and can be read into Wireshark for analysis. Thissaves all the captured packets to the file.

Copy the **Display Filter** into the clipboard, and close and start Wireshark again, then reload the file.Was the whole capture saved or just the displayed packets?
Paste the display filter back into the Filter Bar, and Apply it.

To save only the displayed packets, select **File->Save As** again, but this time select the Displayed radio button rather than the default Captured. This creates a **pcap** file, with only the packets filteredby the current display filter. This can be useful when analysing large captures, as interesting packetscan be saved

Propriétés de sécurité

Cocher si l'algorithme permet d'assurer la propriété.

Algorithme	Confidentialité	Authenticité	Non-repudiation	Disponibilité
MAC				
Signature digitale				

Vrai/faux (7 points)

Répondre par vrai/faux et justifier votre réponse. Une réponse mal justifiée est considérée fausse.

1. Si le compte email d'Alice alice@gmail.com n'est pas piraté, on peut être sûr que seule Alicepeut lire les emails destinés à alice@gmail.com.
2. Alice utilise SSL pour accéder à la page web de sa banque. Un adversaire Dolev Yao ne peutpas voir le mot de passe d'Alice, mais peut voir qu'Alice accède au site web de sa banque.
3. Si Alice et Bob partagent une clé symétrique secrète k et Alice reçoit un message crypté en utilisant k, Alice peut être sûre que le message vient de Bob.

4. Un étudiant ingenieurie ne veut pas utiliser la libraire openPGP car il pense que la librairie a été écrite par un gouvernement étranger qui veut l'espionner. L'étudiant prend un livre de cryptographie et implémente les algorithmes décrits

dans ce livre. Si l'implémentation de l'étudiant est correcte, les algorithmes seront sécurisés.

5. Les sites web de phishing ont forcément un certificat qui n'est pas valide.

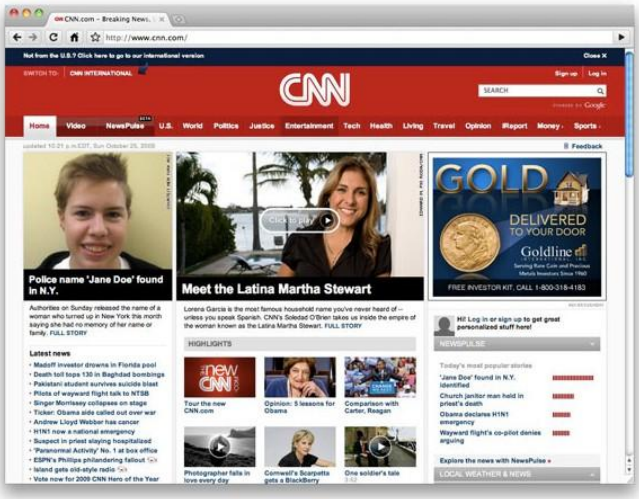
Phishing

Est-ce que les sites ci-dessous sont des sites de phishing ?
Expliquer

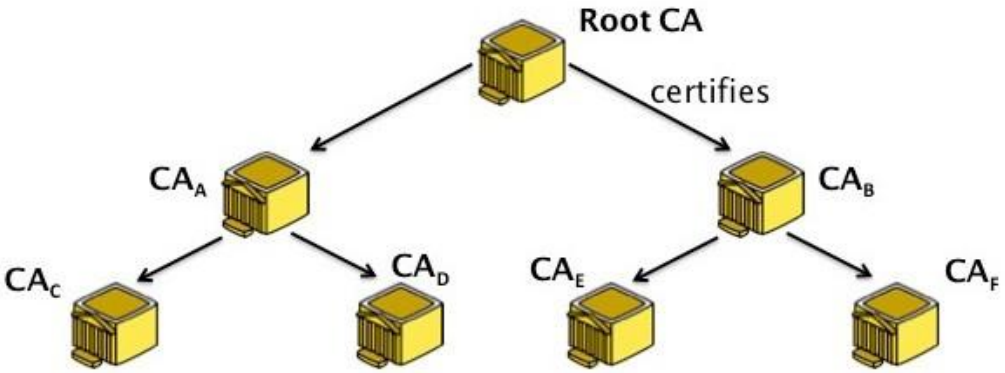
a)

b)

c)



CA vs PGP



On considère la hiérarchie des autorités de certification ci---dessus. On assume aussi que CAD signe un certificat pour https://secure_banque.fr

1) Si Alice essaie de visiter le site https://secure_banque.fr, quel(s) est(sont) les certificat(s) que le navigateurs web d'Alice doit vérifier ?
2) Supposons qu'Alice et Bob suivent correctement toutes les étapes pour créer des certificats et pour utiliser le protocole SSL. Est ce que le CA ou une autre entité peut faire une attaque Man---in---the--- Middle et lire le contenu de la conversation d'Alice et de Bob ? Expliquer.
3) Supposons qu'Alice et Bob suivent correctement toutes les étapes pour échanger les clés publiques et utiliser PGP. Est ce qu'il y a une entité qui peut lancer une attaquer Man---in---the---Middle sur Alice et Bob.
4) Qu'est ce qui est plus utilisé sur Internet : PGP ou SSL ? Donner une raison pourquoi un protocole est beaucoup plus utilisé que l'autre.

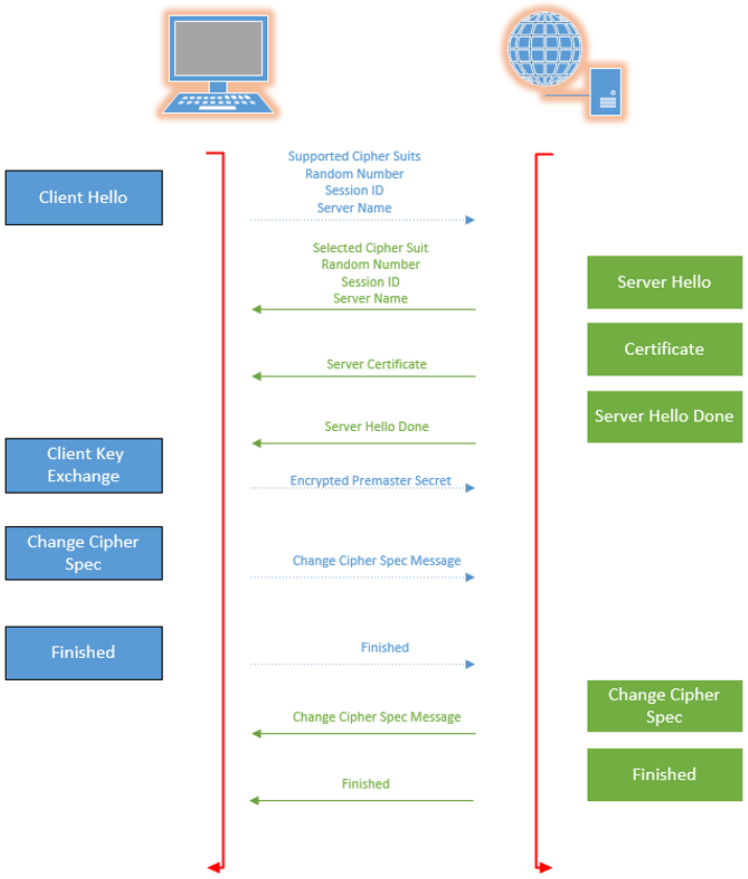
Interception de traffic réseau

On assume que Mallory a accès au réseau LAN d'Alice.

1) Alice accède à une page http
   a. Est---ce que Mallory peut voir le contenu de la page qu'Alice voit ? Justifier
   b. Est---ce que Mallory peut modifier le contenu de la page qu'Alice voit? Justifier
   c. Est---ce que Mallory peut connaître le nom de page qu'Alice voit ? Justifier
2) Alice accède à une page https
   a. Est---ce que Mallory peut voir le contenu de la page qu'Alice voit? Justifier
   b. Est---ce que Mallory peut modifier le contenu de la page qu'Alice voit? Justifier
   c. Est ce que Mallory peut connaître le nom de la page qu'Alice voit ? Justifier

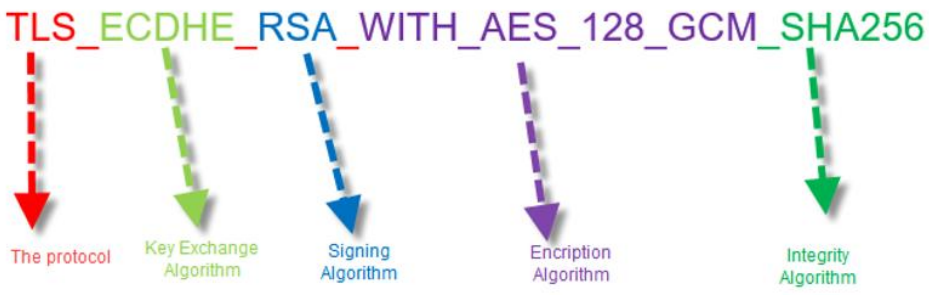
Analyze TLS Handshake with Wireshark

A typical TLS (TLS version 1.2) handshake is summarized below, assuming RSA key exchange used.



Le client commence une nouvelle poignée de main avec un Client Hello et soumet ses capacités. Comme on le voit ci-dessous, le paquet Client Hello contient les combinaisons de chiffrement qu'il prend en charge, l'hôte (info.cern.ch) auquel il veut se connecter, le protocole d'application qu'il protégera (http/1.1), les versions de TLS et l'algorithme de signature qu'il prend en charge, etc. Comme le client supporte les versions 1.2 et 1.3 de TLS, il envoie les combinaisons de chiffrement dans deux formats différents.

TLS version 1.2 cipher suit format is like below:



TLS version 1.3 cipher suit format is like below:

TLS_AES_128_GCM_SHA256

1. Pour lister les types de chiffrement disponible pour SSL/TLS essayes la command suivant:

   Openssl ciphers -v

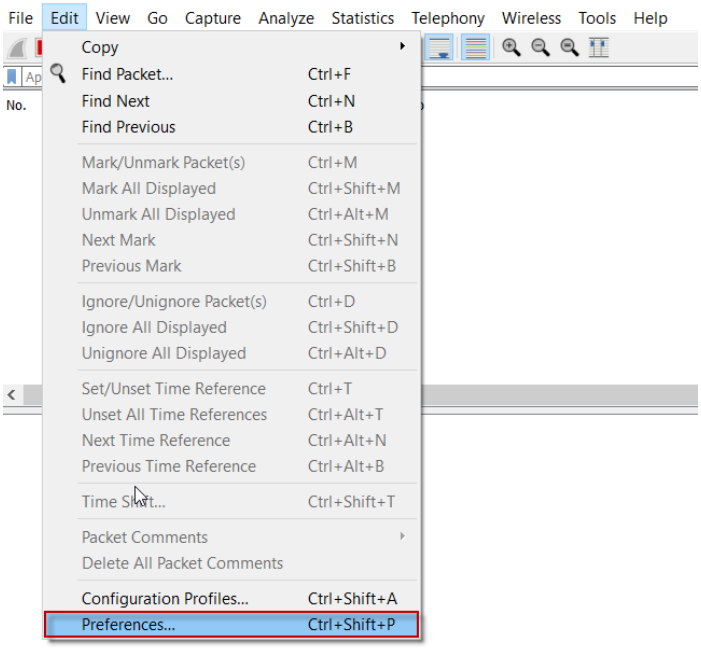
```
C:\Users\nani_>openssl ciphers -v
TLS_AES_256_GCM_SHA384  TLSv1.3 Kx=any      Au=any  Enc=AESGCM(256) Mac=AEAD
TLS_CHACHA20_POLY1305_SHA256 TLSv1.3 Kx=any      Au=any  Enc=CHACHA20/POLY1305(256) Mac=AEAD
TLS_AES_128_GCM_SHA256  TLSv1.3 Kx=any      Au=any  Enc=AESGCM(128) Mac=AEAD
ECDHE-ECDSA-AES256-GCM-SHA384 TLSv1.2 Kx=ECDH     Au=ECDSA Enc=AESGCM(256) Mac=AEAD
ECDHE-RSA-AES256-GCM-SHA384 TLSv1.2 Kx=ECDH     Au=RSA  Enc=AESGCM(256) Mac=AEAD
DHE-RSA-AES256-GCM-SHA384 TLSv1.2 Kx=DH       Au=RSA  Enc=AESGCM(256) Mac=AEAD
ECDHE-ECDSA-CHACHA20-POLY1305 TLSv1.2 Kx=ECDH     Au=ECDSA Enc=CHACHA20/POLY1305(256) Mac=AEAD
ECDHE-RSA-CHACHA20-POLY1305 TLSv1.2 Kx=ECDH     Au=RSA  Enc=CHACHA20/POLY1305(256) Mac=AEAD
DHE-RSA-CHACHA20-POLY1305 TLSv1.2 Kx=DH       Au=RSA  Enc=CHACHA20/POLY1305(256) Mac=AEAD
ECDHE-ECDSA-AES128-GCM-SHA256 TLSv1.2 Kx=ECDH     Au=ECDSA Enc=AESGCM(128) Mac=AEAD
ECDHE-RSA-AES128-GCM-SHA256 TLSv1.2 Kx=ECDH     Au=RSA  Enc=AESGCM(128) Mac=AEAD
DHE-RSA-AES128-GCM-SHA256 TLSv1.2 Kx=DH       Au=RSA  Enc=AESGCM(128) Mac=AEAD
ECDHE-ECDSA-AES256-SHA384 TLSv1.2 Kx=ECDH     Au=ECDSA Enc=AES(256)  Mac=SHA384
ECDHE-RSA-AES256-SHA384 TLSv1.2 Kx=ECDH     Au=RSA  Enc=AES(256)  Mac=SHA384
DHE-RSA-AES256-SHA256   TLSv1.2 Kx=DH       Au=RSA  Enc=AES(256)  Mac=SHA256
ECDHE-ECDSA-AES128-SHA256 TLSv1.2 Kx=ECDH     Au=ECDSA Enc=AES(128)  Mac=SHA256
ECDHE-RSA-AES128-SHA256 TLSv1.2 Kx=ECDH     Au=RSA  Enc=AES(128)  Mac=SHA256
DHE-RSA-AES128-SHA256   TLSv1.2 Kx=DH       Au=RSA  Enc=AES(128)  Mac=SHA256
ECDHE-ECDSA-AES256-SHA  TLSv1 Kx=ECDH     Au=ECDSA Enc=AES(256)  Mac=SHA1
ECDHE-RSA-AES256-SHA    TLSv1 Kx=ECDH     Au=RSA  Enc=AES(256)  Mac=SHA1
DHE-RSA-AES256-SHA      SSLv3 Kx=DH       Au=RSA  Enc=AES(256)  Mac=SHA1
ECDHE-ECDSA-AES128-SHA  TLSv1 Kx=ECDH     Au=ECDSA Enc=AES(128)  Mac=SHA1
```

Prenez le remps de parcourir cette liste et de voir les champs : Kx, Auth, Enc, Mac

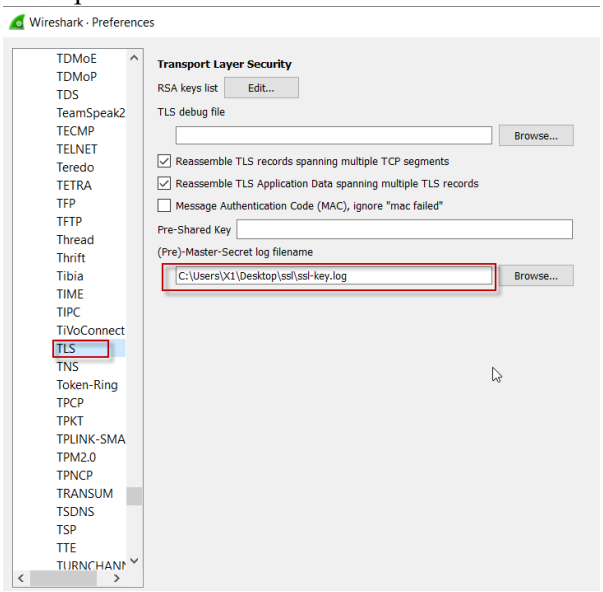
2. Lancez la capture "**TLS Decryption_Anass_Sebbar.pcapng**"
3. Analyser la capture TLS
   a. Visualiser et analyser le champ **client hello**
   b. Visualiser et analyser le champ **Server hello**
   c. Vous remarquer quoi?
   d. Est-ce que le serveur a envoyé certifica?
   e. Est-ce que la certificate est valide?

f. Decriver l'echange entre client et server pour etablire une connection securisé?
g. Quel est le non domaine visité?
h. Est-ce que le non-domaine que j'ai visité est https?

Maintenant pour decrypter votre capture TLS vous devez ajouter le fichier log suivant "**sslkeylog.log**" . Ensuite, cliquez sur le menu Edit, puis sur Preferences et la fenêtre Wireshark-Preferences apparaîtra. Dans le volet de gauche, vous verrez "Protocoles", cliquez dessus pour développer l'arbre. Faites défiler vers le bas, puis cliquez sur TLS.



À partir de "(Pre)-Master-Secret log filename" , utilisez le bouton Parcourir ou collez le chemin du fichier journal et cliquez sur OK pour terminer.



4. Analyser les paquets avant et après le décryptage de la capture Wireshark?